

1. Visión General del Sistema

Debacu Evaluation360 es una plataforma SaaS B2B orientada al sector hotelero para:

- Registro estructurado de incidencias y evaluaciones
- Gestión de riesgo por cliente
- Control de acceso multiusuario según plan contratado
- Auditoría y exportación de datos
- Cumplimiento RGPD/LOPDGDD
- Monetización vía Stripe (suscripciones recurrentes)

Arquitectura orientada a:

- Seguridad
 - Separación estricta por cliente (multi-tenant)
 - Validación de planes desde backend
 - Eliminación total de RPC
-

2. Arquitectura Técnica

2.1 Frontend

- **Framework:** React
- **Lenguaje:** TypeScript
- **Bundler:** Vite
- **Estilos:** TailwindCSS
- **Autenticación:** Supabase Auth
- **Comunicación backend:** Exclusivamente Edge Functions (REST)

Reglas activas:

- No hay lógica sensible en frontend
 - No se accede directamente a tablas críticas
 - No se usan RPC
 - Nunca se usa service_role en cliente
-

2.2 Backend

Proveedor: Supabase

Componentes utilizados:

- PostgreSQL
- Row Level Security (RLS)
- Edge Functions (Deno)
- Storage Buckets
- Auth
- Webhooks Stripe

Principio clave:

Toda la lógica sensible está en Edge Functions.

3. Modelo Multi-Tenant

Cada cliente (hotel) está aislado por:

- `customer_id`
- RLS en todas las tablas
- Validación adicional en Edge Functions
- Nunca se exponen datos de otros clientes

Modelo:

Usuario → pertenece a → Customer

Customer → tiene → Plan

Plan → determina → nº usuarios + límites

4. Gestión de Suscripciones

Planes actuales

Plan	Usuarios	Observaciones
FREE	1	30 días prueba
BASIC	1	Stripe activo
MEDIUM	2	Stripe activo
PREMIUM	4	Stripe activo

Integración Stripe

- Productos creados
- Price IDs guardados en secrets
- Webhook activo

- Estados manejados:
 - ACTIVE
 - PENDING_PAYMENT
 - CANCELED
 - TRIAL

Tablas relacionadas:

- subscriptions
- subscription_events
- invoices

Validación:

- Siempre en backend
 - Nunca confiando en frontend
-

5. Tablas Principales

Núcleo de negocio

- debacu_eval_customers
- debacu_eval_users
- debacu_eval_evaluations
- debacu_eval_access_requests
- debacu_eval_usage_alerts
- debacu_eval_config_changes

Suscripciones y facturación

- subscriptions
- subscription_events
- invoices

Auditoría

- audit_exports
 - audit_export_downloads
-

6. Seguridad y Cumplimiento

RGPD / LOPDGDD

Reglas activas:

- No exposición de PII en vistas agregadas
- No salida de datos individuales en consultas globales
- Enmascarado en frontend solo visual
- Acceso individual solo al cliente propietario
- ADMIN con acceso restringido y auditado

RLS

- Activado en todas las tablas sensibles
- Políticas por:
 - customer_id
 - role
 - plan

Buckets

- system-exports
 - Descargas firmadas
 - Registro de descargas
-

7. Eliminación de RPC

Estado actual:

- Migración progresiva a Edge Functions
- Objetivo: 0 RPC activas
- Toda validación de plan y permisos en backend

Motivo:

- Mayor control
 - Mejor auditoría
 - Más seguridad
 - Menor exposición accidental
-

8. Estado Técnico Actual (Realista)

Fortalezas

- Arquitectura moderna
- Separación clara frontend/backend
- Planes Stripe integrados
- RLS activo
- Sistema de auditoría en desarrollo
- Multiusuario controlado por plan

Riesgos / Puntos a revisar

- Validación exhaustiva de límites por plan
 - Consistencia en naming camelCase vs snake_case
 - Gestión robusta de cambios de plan
 - Gestión correcta de downgrade
 - Verificación completa de CORS en todas las funciones
 - Revisión total de que ninguna función exponga más datos de los necesarios
-

9. Principios Técnicos Activos

1. Nunca lógica sensible en frontend.
 2. Nunca confiar en datos del cliente.
 3. Siempre validar plan en backend.
 4. Prefijo obligatorio `debaeu_eva l_` en tablas nuevas.
 5. `snake_case` en BD, `camelCase` en frontend.
 6. Edge Functions como única capa lógica.
 7. Auditoría trazable en acciones críticas.
 8. Minimización de datos como principio legal.
-

10. Próximas Consolidaciones Necesarias

- Auditoría completa de todas las Edge Functions
- Validación centralizada de plan (middleware común)
- Documentación formal de downgrade/upgrade

- Sistema definitivo de límite de usuarios
- Test de penetración básico interno
- Revisión legal básica de exportaciones